

# Resolve ReDoS opportunity by fixing incorrectly specified regex #2906

[New issue](#)
[Merged](#)

tomaarsen merged 1 commit into `nlTK:develop` from `tomaarsen:bugfix/regex-tagger-redos` on Dec 8, 2021

[Conversation](#) 2 [Commits](#) 1 [Checks](#) 0 [Files changed](#) 6 +20 -20 ■ ■ ■ ■



tomaarsen commented on Dec 8, 2021

Member

Hello!

## Pull request overview

- Resolve slight ReDoS in some RegexpTaggers throughout NLTK.
- Modified doctests to accompany the changed regex.

## The regex

The original regex was `^-?[0-9]+(.[0-9]+)?$`, which is vulnerable to a ReDoS due to `[0-9]+` followed by any character (due to `.`), and then again `[0-9]+`. However, this original regex does not seem to match what it was intended for: Matching cardinal numbers. The regex seems to want to match:

- Perhaps a `-`
- A non-zero amount of numbers.
- Perhaps a `.` followed by a non-zero amount of numbers.

This would match e.g. `3`, `-4` and `3.12`. However, the regex actually does not match a dot directly, it matches any number. This means that `-3a12` is also allowed, which we would rather not have. I believe the original designer of the regex meant to use `\.`, but used `.` instead, and did not realise the small mistake.

## ReDoS reproduction:

### Reviewers



purificant



### Assignees

No one assigned

### Labels

bug

### Projects

None yet

### Milestone

No milestone

### Development

Successfully merging this pull request may close these issues.

None yet

### 2 participants



```
pattern = re.compile(r"^-[0-9]+(.[0-9]+)?$")
```



```
for length in (2**i for i in range(12, 24)):
    s = "-"
    s += "0" * length
    s += "q"

    t = time.time()
    re.search(pattern, s)
    print(f"Searching took {time.time() - t:.8}s for
```

outputs

```
Searching took 0.17596316s for length 4096.
Searching took 0.66382051s for length 8192.
Searching took 2.8454814s for length 16384.
Searching took 10.864819s for length 32768.
Searching took 44.40001s for length 65536.
Searching took 176.56144s for length 131072.
...
```



After several minutes I stopped the execution.

## The fix

Simply adding a `\` before the `.` should fix the problem.

## The consequences

The regex will no longer be vulnerable to a ReDoS. Beyond that, `-3a12` will no longer be considered a cardinal number in the RegexpTagger examples throughout NLTK. This is desirable behaviour, with one small subjective exception: `3e12` will no longer be considered a cardinal number, even though one could argue that it is.

If we want to still consider it one, then we can of course go for `^-[0-9]+([e\.[0-9]+])?$`, but I really don't think it matters.

## ReDoS reproduction

```
pattern = re.compile(r"^-[0-9]+(.[0-9]+)?$")
```



```
for length in (2**i for i in range(12, 24)):
    s = "-"
    s += "0" * length
    s += "q"

    t = time.time()
    re.search(pattern, s)
    print(f"Searching took {time.time() - t:.8}s for
```

now outputs

```
Searching took 0.0s for length 4096.
Searching took 0.0010306835s for length 8192.
Searching took 0.00096130371s for length 16384.
Searching took 0.0020515919s for length 32768.
Searching took 0.0029797554s for length 65536.
Searching took 0.0060167313s for length 131072.
Searching took 0.013041735s for length 262144.
Searching took 0.026050091s for length 524288.
Searching took 0.051049709s for length 1048576.
Searching took 0.09999752s for length 2097152.
Searching took 0.20596671s for length 4194304.
Searching took 0.40702796s for length 8388608.
```

As is correct for a simple regex, the execution time of the regex is linear in the length of the input. This was not the case before.

Thanks to [@Scara31](#) for making us aware of this vulnerability through proper means.

- Tom Aarsen



Resolve ReDoS opportunity by fixing [incorrectly specified regex](#) ...

[babdabb](#)



**tomaarsen** added the **bug** label on [Dec 8, 2021](#)



**tomaarsen** commented on [Dec 8, 2021](#)

Member

Author

How to reproduce in NLTK:

```
from nltk.parse.malt import malt_regex_tagger

tagger = malt_regex_tagger()
length = 50000
t = time.time()
tagger(["-" + "0" * length + "q"])
print(f"Tagging took {time.time() - t:.8}s for length {length}")
```

Outputs the following in this PR:

```
Tagging took 0.0020170212s for length 50000.
```

And outputs the following in `develop`

```
Tagging took 26.010252s for length 50000.
```



**purificant** approved these changes [on Dec 8, 2021](#)

[View reviewed changes](#)

**purificant** left a comment

Member

LGTM



1



**tomaarsen** merged commit **2a50a3e** into [nltk:develop](#) [on Dec 8, 2021](#)



**tomaarsen** deleted the [bugfix/regex-tagger-redos](#) branch [5 years ago](#)



**tomaarsen** mentioned this pull request [on Jan 14, 2022](#)

**Regular Expression Denial of Service (ReDoS) from RegexpTagger #2929**

✓ Closed



**icanhasmath** pushed a commit to ActiveState/nltk that referenced this pull request [on Dec 22, 2023](#)



[Resolve ReDoS opportunity by fixing incorrectly specified regex \(nltk...](#)

[4757a3b](#)

...



**MatthewZMD** added a commit to ActiveState/nltk that referenced this pull request [on Dec 22, 2023](#)



[Merge pull request #2 from ActiveState/cve-2021-3842](#)

Verified

[41d217b](#)

...